الجمهورية اليمنية - وزارة التعليم العالي والبحث العلمي

Sana'a Community College | كلية المجتمع بصنعاء

مشروع تخرج متقدم - تخصص الأمن السيبراني

نظام إدارة الهويات والوصول في البيئة السحابية

Cloud Identity and Access Management System (IAM)

وثيقة تقنية وأكاديمية متكاملة لاستعراض التصميم المعماري والأمني لنظام IAM مبني على قواعد بيانات Oracle 21c وتكنولوجيا Oracle APEX 21c وفق أفضل ممارسات الأمن السحابي.

إعداد الطالب / Student Name

Mohammed Abdulmalik Zaid Salem Al-Hattami

القسم الأكاديمي / Department

الأمن السيبراني (Cybersecurity)

المادة / Course

أنظمة قواعد البيانات (Database Systems)

العام الأكاديمي / Year

2026 م

القسم الثاني: فكرة المشروع (Project Idea)

الافتتاحية التنفيذية: تُشكل الحماية الرقمية في العصر السحابي تحدياً جوهرياً يتجاوز الحدود الجغرافية والشبكية التقليدية. مع تلاشي محيط الشبكة التقليدي (Perimeter Alignment)، أصبحت "الهوية الرقمية" هي خط الدفاع الأول والأخير. يقدم هذا المشروع نظاماً متكاملاً لإدارة الهويات والوصول (IAM) مصمم بأسلوب محاكاة الأنظمة السحابية العملاقة لضبط وتنظيم الهويات، الصلاحيات، والعمليات بدقة متناهية.

ما هو نظام IAM؟ نظام إدارة الهويات والوصول (Identity and Access Management) هو إطار عمل أمني وتقني يضمن وصول الأشخاص المصرح لهم فقط إلى الموارد المحددة في الوقت المناسب وللأسباب الصحيحة. يرتكز النظام على معادلة الثلاثية الأمنية: التوثيق (Authentication)، التفويض (Authorization)، والمساءلة (Accountability).

أهميته في البيئة السحابية: في المنظومات السحابية (Cloud Infrastructure)، لا توجد جدران نارية فزيائية تفصل المستخدم عن البيانات. يعتمد تقديم الخدمات على بيئات متقدمة مثل AWS IAM و Azure AD و Google Cloud IAM، حيث يُمثل نظام IAM العمود الفقري الذي يُلزم المنشآت بتطبيق نموذج "Zero Trust" (عدم الثقة المطلقة والتحقق الدائم).

القسم الثالث: الدافع والإنشغال البحثي (Motivation & Inspiration)

Personal Motivation & Industry Context .03

"بصفتي طالباً متفوقاً في قسم الأمن السيبراني، أدركت منذ بداية مسيرتي الأكاديمية أن التخصص الحقيقي يتطلب الابتعاد عن النمطية. لم يكن شغفي يتوقف عند بناء تطبيقات تقليدية، بل كان يطمح دائماً نحو هندسة البنية التحتية الأمنية للمستقبل."

لاحظت خلال دراستي أن غالبية مشاريع التخرج الطلابية تقتصر على أنظمة إدارة مبسطة (كالمكتبات، المستشفيات، أو نقاط البيع). ورغم أهمية هذه الأنظمة تعليمياً، إلا أنها لا تعكس التحديات الحقيقية التي تواجه سوق العمل اليوم في مجال الأمن السحابي (Cloud Security).

تُشير التقرير العالمية الحديثة - مثل تقرير Verizon DBIR وتقارير IBM Security - إلى أن أكثر من **80% من الاختراقات الأمنية السيبرانية** الناجحة ناتجة عن إساءة استخدام الصلاحيات، سوء إدارة الهويات، أو سرقة بيانات الاعتماد. من هنا نبعت الفكرة: بناء نظام IAM متكامل باستعمال تقنيات Oracle Enterprise لمعالجة الجذور الحقيقية للثغرات الأمنية.

القسم الرابع: الوصف التقني والمعماري (Project Architecture)

تم بناء المشروع باستخدام بيئة **Oracle Database 21c** وواجهة **Oracle APEX 21c** كمنظومة قواعد بيانات متقدمة اعتمدت على 10 جداول رئيسية مترابطة لإحكام السيطرة والتحكم:

اسم الجدول	نوع العلاقة	الوظيفة الأمنية والتقنية
USERS	رئيسي (N:1)	تخزين بيانات المستخدمين، كلمات المرور المشفرة (Hash) مع Salt خاص.
ROLES	رئيسي (N:1)	تعريف الأدوار (Admin, Security Analyst, Auditor, Manager, Dev, Viewer).
PERMISSIONS	رئيسي (N:1)	تحديد العمليات المسموحة (CREATE, READ, UPDATE, DELETE) على الموارد.
USER_ROLES	M:N (وسيط)	ربط المستخدمين بالأدوار المخصصة لهم بحسب الهيكل التنظيمي.
ROLE_PERMISSIONS	M:N (وسيط)	ربط الأدوار بالصلاحيات الفرعية لتنفيذ نموذج RBAC الشامل.
POLICIES	N:1	تطبيق سياسات الوصول المشروط (نطاق IP، ساعات العمل، حد المحاولات).
ACCESS_LOGS	N:1	توثيق عمليات تسجيل الدخول (نجاح/فشل) مع عنوان IP وUser Agent.
MFA_TOKENS	N:1	إدارة رموز التحقق المؤقتة (OTP) لتعزيز الأمان عبر المصادقة الثنائية.
SESSIONS	N:1	تتبع الجلسات النشطة وإنهائها تلقائياً عند التجاوز الزمني أو الريبة.
AUDIT_TRAIL	N:1	سجل تدقيق أمني لتسجيل كل عملية تعديل أو حذف (قبل/بعد التعديل).

المشغلات البرمجية (Triggers & PL/SQL)

استخدام `BEFORE INSERT` لتشفير كلمات المرور آلياً بنظام Salt/Hash قبل تخزينها، و`AFTER UPDATE/DELETE` لترحيل بيانات التعديل فوراً إلى جدول التدقيق (AUDIT_TRAIL).

الرؤى التحليلية (Analytical Views)

بناء الـ View التحليلي `V_USER_ACCESS` لتوفير تقارير فورية تربط المستخدم بجميع الأدوار والصلاحيات والسياسات المطبقة عليه لسهولة المراجعة والتدقيق.

القسم الخامس: المشاكل الأمنية والحلول المنفذة (Problem Statement & Solutions)

يعالج النظام 7 مشاكل حرجة تواجه المؤسسات في إدارة الهويات والوصول في البيئات الحديثة:

1. ضعف كلمات المرور وهجمات Rainbow Tables

السرية والتشفير

الحل: تطبيق خوارزميات التشفير غير العكسي (Cryptographic Hashing) مع توليد Salt عشوائي فريد لكل مستخدم، مما يمنع فك تشفير البيانات حتى لو تم تسريب قاعدة البيانات.

2. عشوائية وتضخم الصلاحيات (IAM Sprawl)

إدارة الصلاحيات

الحل: اعتماد نموذج RBAC الشارم ومبدأ "أقل صلاحية" (Least Privilege)، حيث لا يمنح المستخدم أي صلاحية مباشرة بل عبر أدوار وظيفية محددة بدقة.

3. غياب المساءلة وصعوبة التتبع (Lack of Auditability)

الرقابة والتدقيق

الحل: تفعيل جدول AUDIT_TRAIL الآلي المربوط بالمشغلات (Triggers)، لتوثيق من قـام بالتعديل، ما هـو التعديل، والوقت المحدد بالثواني.

4. هجمات انتحال الهوية والقوة الغاشمة (Brute Force)

الحماية النشطة

الحل: دمج التحقق بخطوتين (MFA/OTP) وتحديد سياسات القفل التلقائي للحساب بجدول POLICIES بعد عدد محدد من المحاولات الخاطئة.

5. اختطاف الجلسات النشطة (Session Hijacking)

إدارة الجلسات

الحل: إدارة الجلسات عبر جدول SESSIONS مع ربطه بعنوان الـ IP ورقم المتصفح وتنفيذ الإنهاء الآلي (Auto Timeout) عند عدم النشاط.

6. غياب السياسات الأمنية الموحدة

السياسات والامتثال

الحل: بناء محرك سياسات ديناميكي يفرض شروط الوصول حسب الموقع الجغرافي (IP Range) وساعات العمل المسموحة.

القسم السادس: القيمة والأثر (Project Value & Learning Outcome)

06. Project Impact & Academic Value

تكمن قيمة هذا المشروع في تحويل المفاهيم النظرية للأمن السيبراني إلى واقع تطبيقي ملموس. أتاح المشروع فرصة للتعمق في هندسة قواعد بيانات المؤسسات (Enterprise Database Engineering)، وفهم الآليات البرمجية المعقدة لربط الأمان بمستوى قواعد البيانات (Database-Level Security) بدلاً من الاعتماد الكلي على طبقة التطبيق.

القسم السابع: الخاتمة والتطلعات (Conclusion & Future Work)

07. Conclusion & Roadmap

يمثل هذا مشروع IAM خطوة أولى نحو بناء منصة أمان سحابية شاملة. أثبتت التجربة أن استخدام Oracle APEX مع PL/SQL يوفر بيئة عالية الكفاءة لتطبيق معايير Zero Trust.

التطويرات المستقبلية المخطط لها:

- دعم الربط عبر بروتوكولات الهوية الموحدة مثل SAML 2.0 و OAuth 2.0 / OpenID Connect.
- التكامل المباشر مع مزودي الخدمات السحابية (AWS Secrets Manager & Azure Key Vault).
- إدخال خوارزميات الذكاء الاصطناعي لكشف الشذوذ في سلوك تسجيل الدخول (Anomaly Detection).

القسم الثامن: المراجع الأكاديمية والتقنية (References)

08. Academic & Technical References

1. **NIST Special Publication 800-207:** Zero Trust Architecture. National Institute of Standards and Technology, 2020.
2. **NIST Special Publication 800-63B:** Digital Identity Guidelines: Authentication and Lifecycle Management. NIST, 2020.
3. **OWASP Foundation:** OWASP Top 10 Security Risks - Broken Access Control & Identification Failures, 2021.
4. **Verizon Business:** Data Breach Investigations Report (DBIR) - Credential & Privilege Analysis, 2023-2024.
5. **Oracle Corporation:** Oracle Database Security Guide 21c & Oracle APEX Security Best Practices, 2022.